

NGcourses

Reporte de Correcciones de Seguridad

Fecha de emisión:	2026-05-18
Versión del proyecto:	rama main — commit b168727
Auditoría base:	2026-05-09 (commit 3d1818e)
Alcance:	Frontend Next.js 16 + Backend FastAPI + Docker/CI-CD
Nivel de confidencialidad:	Interno — no distribuir

1. Resumen Ejecutivo

Este documento registra el estado de remediación de los 27 hallazgos de seguridad identificados en la auditoría estática de NGcourses (2026-05-09). Los hallazgos cubren el stack completo: frontend Next.js 16, backend FastAPI, configuración Docker y pipeline CI/CD en GitHub Actions → AWS ECR → EC2. La auditoría detectó 3 hallazgos críticos, 8 altos, 9 medios y 7 bajos. Al cierre de este reporte, 25 de 27 hallazgos están resueltos o no requerían acción (FND-022 preventivo). Un hallazgo (FND-020, HTTPS) queda pospuesto hasta que se asigne el dominio del proyecto.

Severidad	Hallazgos	Resueltos	Pendientes
Crítico	3	3	0
Alto	8	8	0
Medio	9	8	1
Bajo	7	6	0
Total	27	25	1

De los 27 hallazgos: **5** resueltos en este sprint, **17** resueltos en sprints anteriores, **3** ya estaban resueltos en el código (sin commit previo registrado), **1** preventivo (FND-022, sin acción), **1** pospuesto (FND-020, sin dominio).

2. Tabla Maestra de Hallazgos

ID	Severidad	Título	Estado	Sprint
FND-001	Critico	Mass assignment / escalada vertical	Resuelto	Anterior
FND-002	Critico	Sin rate limiting en endpoints públicos	Resuelto	Anterior
FND-003	Critico	JWT en localStorage sin HttpOnly/Secure	Resuelto	Anterior
FND-004	Alto	User enumeration en /password-recovery	Resuelto	Anterior
FND-005	Alto	Sin protección server-side de rutas (middleware muerto)	Resuelto	Anterior
FND-006	Alto	SECRET_KEY sin default obligatorio	Resuelto	Código
FND-007	Alto	JWT de 8 días sin refresh token ni revocación	Resuelto	Este sprint
FND-008	Alto	Sin headers de seguridad	Resuelto	Anterior
FND-009	Alto	Race condition en emisión de certificados (TOCTOU)	Resuelto	Anterior
FND-010	Alto	Race condition pago + inscripción (no atómicos)	Resuelto	Anterior
FND-011	Alto	IP pública de EC2 hardcodeada en el workflow	Resuelto	Anterior
FND-012	Medio	CORS con allow_headers=["*"] + allow_credentials=True	Resuelto	Anterior
FND-013	Medio	Validación MIME por header sin magic bytes	Resuelto	Anterior
FND-014	Medio	Token de reset password viaja en URL (query param)	Resuelto	Anterior
FND-015	Medio	Cookies de rol sin flag Secure	Resuelto	Este sprint
FND-016	Medio	Adminer expuesto en docker-compose principal	Resuelto	Anterior
FND-017	Medio	Containers Docker corren como root	Resuelto	Anterior
FND-018	Medio	Endpoint /private activo si ENVIRONMENT=local en prod	Resuelto	Anterior
FND-019	Medio	Comparación de expiración de token con tzinfo forzado ciego	Resuelto	Este sprint
FND-020	Medio	Frontend en HTTP sin TLS (sin dominio aún)	Pospuesto	—
FND-021	Bajo	Sin validación con schemas (Zod) en el frontend	Resuelto	Este sprint
FND-022	Bajo	Sin DOMPurify (preventivo — no hay dangerouslySetInnerHTML)	Preventivo	—
FND-023	Bajo	SECURITY.md con template genérico (email de @tiangolo)	Resuelto	Anterior
FND-024	Bajo	Sin pre-commit hooks (gitleaks / detect-secrets)	Resuelto	Anterior
FND-025	Bajo	Sin Sentry en el frontend (errores de browser invisibles)	Resuelto	Este sprint
FND-026	Bajo	package-lock.json en .gitignore pero versionado	Resuelto	Código
FND-027	Bajo	frontend/Dockerfile copia .env* con COPY . .	Resuelto	Código

3. Detalle de Correcciones por Hallazgo

3.1 Hallazgos Criticos

FND-001	Mass assignment / escalada vertical	Critico	Resuelto
Se refactorizó UserUpdate como clase independiente (no hereda UserBase). Se excluyó is_superuser del schema de actualización. Se agregó model_config = ConfigDict(extra='forbid') para rechazar campos desconocidos. CVSS: 9.1 CWE-915			
Sprint de resolución: Anterior			
FND-002	Sin rate limiting en endpoints públicos	Critico	Resuelto
Se instaló slowapi. Se aplicó @limiter.limit en /login/access-token (5/min), /password-recovery (3/h), /reset-password (5/min), /users/activar (5/min), /users/signup (10/h) y /invitaciones/canjar. CVSS: 8.2 CWE-307			
Sprint de resolución: Anterior			
FND-003	JWT en localStorage sin HttpOnly/Secure	Critico	Resuelto
El backend ahora emite el JWT en cookie HttpOnly, Secure (condicional a ENABLE_HTTPS), SameSite=Strict. Se eliminó localStorage.setItem del frontend. La dep get_current_user lee la cookie en lugar del header Authorization. CVSS: 7.7 CWE-922, CWE-1004			
Sprint de resolución: Anterior			

3.2 Hallazgos Altos

FND-004	User enumeration en /password-recovery	Alto	Resuelto
El endpoint devuelve respuesta uniforme independientemente de si el email existe: 'Si el correo existe en nuestro sistema, recibirás instrucciones.' Se eliminó el HTTP 404 explícito que revelaba existencia de cuenta. CVSS: 5.3 CWE-204			
Sprint de resolución: Anterior			
FND-005	Sin protección server-side de rutas (middleware muerto)	Alto	Resuelto
proxy.ts (código muerto) fue renombrado a middleware.ts. Next.js ahora lo invoca antes de renderizar cualquier página protegida (/admin, /instructor, /supervisor, /perfil). La validación de rol ocurre en el servidor, no en useEffect del cliente. CVSS: 4.3 CWE-602			
Sprint de resolución: Anterior			
FND-006	SECRET_KEY sin default obligatorio	Alto	Resuelto
SECRET_KEY se declaró sin valor default: cualquier arranque sin .env falla de inmediato con ValidationError. Se agregó validador que rechaza 'changethis' y claves < 32 chars en todos los entornos (no solo local). CVSS: 7.4 CWE-798			
Sprint de resolución: Código			

FND-007	JWT de 8 días sin refresh token ni revocación	Alto	Resuelto
ACCESS_TOKEN_EXPIRE_MINUTES reducido a 120 min. Se implementó refresh token con rotación: tabla refresh_tokens en BD (hash SHA-256, nunca el raw), endpoint POST /login/refresh-token con rate limit 20/min, rotación automática (revoke old + insert new). Cliente con interceptor 401 → auto-refresh → retry. Logout revoca el token en BD. CVSS: 6.5 CWE-613			
Sprint de resolución: Este sprint			
FND-008	Sin headers de seguridad	Alto	Resuelto
Se configuraron en next.config.ts: Content-Security-Policy (default-src, script-src, style-src, img-src, connect-src, frame-src, object-src, base-uri, form-action, frame-ancestors 'none'), X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy, Permissions-Policy. HSTS condicional a ENABLE_HTTPS. CVSS: 4.7 CWE-693			
Sprint de resolución: Anterior			
FND-009	Race condition en emisión de certificados (TOCTOU)	Alto	Resuelto
Se agregó UNIQUE constraint en certificado.inscripcion_id vía migración Alembic. check_and_emit_certificate envuelve el commit en try/except IntegrityError: si otra request gana la carrera, se retorna el certificado existente. CVSS: 3.1 CWE-362, CWE-367			
Sprint de resolución: Anterior			
FND-010	Race condition pago + inscripción (no atómicos)	Alto	Resuelto
El bloque pago COMPLETADO + creación de inscripción se unificó en una sola transacción con un único session.commit(). Si el proceso falla a mitad, el rollback automático de SQLAlchemy deja el estado consistente. CVSS: 5.2 CWE-362			
Sprint de resolución: Anterior			
FND-011	IP pública de EC2 hardcodeada en el workflow	Alto	Resuelto
La IP fue movida a un secret de GitHub (EC2_HOST). El workflow usa \${ secrets.EC2_HOST } en todos los comandos SCP/SSH. El remotePattern con IP en next.config.ts fue eliminado. CVSS: 5.3 CWE-200			
Sprint de resolución: Anterior			

3.3 Hallazgos Medios

FND-012	CORS con allow_headers=["*"] + allow_credentials=True	Medio	Resuelto
allow_headers reemplazado por lista explícita: Authorization, Content-Type, X-Requested-With y headers TUS. Se eliminó el regex de allow_origin para túneles loca.lt/ngrok en entornos que no sean local. CVSS: 4.7 CWE-942			
Sprint de resolución: Anterior			

FND-013	Validación MIME por header sin magic bytes	Medio	Resuelto
Se agregó validación de magic bytes con python-magic en los endpoints de upload de portada de curso y recursos de lección. El tipo real del archivo se detecta sobre los primeros 4 KB, rechazando archivos con cabecera falsa. CVSS: 5.4 CWE-434			
Sprint de resolución: Anterior			
FND-014	Token de reset password viaja en URL (query param)	Medio	Resuelto
El token se eliminó del query param y ahora viaja en el body del POST que el formulario envía internamente. El link del email apunta a la página /reset-password que lee el token del fragmento (#token=...) vía JS, evitando que quede en logs de proxies o historial del navegador. CVSS: 6.8 CWE-598			
Sprint de resolución: Anterior			
FND-015	Cookies de rol sin flag Secure	Medio	Resuelto
Se agregó flag Secure de forma condicional en setRolCookies: se detecta window.location.protocol === 'https:' en tiempo de ejecución. En HTTP (EC2 sin dominio) el flag se omite correctamente. En HTTPS (producción final) se incluye automáticamente. CVSS: 3.1 CWE-352			
Sprint de resolución: Este sprint			
FND-016	Adminer expuesto en docker-compose principal	Medio	Resuelto
El servicio adminer fue movido a docker-compose.dev.yml (solo desarrollo). Se le agregó middleware Traefik de basicauth. docker-compose.prod.yml nunca lo incluye. CVSS: 9.8 si prod / 0 en dev CWE-489			
Sprint de resolución: Anterior			
FND-017	Containers Docker corren como root	Medio	Resuelto
backend/Dockerfile: se creó usuario appuser (UID 1000) y se estableció USER appuser antes del CMD. frontend/Dockerfile: se usa el usuario node incluido en node:alpine y se asignan permisos con --chown=node:node en las instrucciones COPY del stage runner. CVSS: 7.5 CWE-250			
Sprint de resolución: Anterior			
FND-018	Endpoint /private activo si ENVIRONMENT=local en prod	Medio	Resuelto
Se agregó dependency _require_local_env al router /private que verifica settings.ENVIRONMENT en runtime y retorna HTTP 404 si no es 'local'. Doble barrera: la condición en main.py (include condicional) + la dep interna. CVSS: 9.1 si mal conf. CWE-489			
Sprint de resolución: Anterior			
FND-019	Comparación de expiración de token con tzinfo forzado ciego	Medio	Resuelto
Se reemplazó el patrón .replace(tzinfo=timezone.utc) ciego por una verificación previa: si dt.tzinfo is None → replace; si ya es aware → usar directamente. Aplicado en reset_password (login.py) y en activar_cuenta (users.py). CVSS: 3.7 CWE-754			
Sprint de resolución: Este sprint			

FND-020	Frontend en HTTP sin TLS (sin dominio aún)	Medio	Pospuesto
Sin dominio asignado al momento de la auditoría (subdominio pendiente en ncchamp). El código ya está preparado: <code>secure=settings.ENABLE_HTTPS</code> en cookies, <code>httpsEnabled</code> en CSP y HSTS. Cuando se active el dominio: levantar Traefik con Let's Encrypt (<code>docker-compose.traefik.yml</code> existente) y setear <code>ENABLE_HTTPS=true</code> . CVSS: 6.8 CWE-319			
Sprint de resolución: —			

3.4 Hallazgos Bajos

FND-021	Sin validación con schemas (Zod) en el frontend	Bajo	Resuelto
Se instaló zod. Se crearon <code>frontend/src/schemas/auth.ts</code> , <code>profile.ts</code> y <code>user.ts</code> con schemas de <code>LoginSchema</code> , <code>ResetPasswordSchema</code> , <code>ActivarCuentaSchema</code> , <code>EditProfileSchema</code> , <code>ChangePasswordSchema</code> , <code>ProfileSetupSchema</code> , <code>CreateUserSchema</code> , <code>EditUserSchema</code> . Los 8 formularios ahora llaman <code>Schema.safeParse()</code> antes del fetch y muestran errores inline. CVSS: 0 CWE-20			
Sprint de resolución: Este sprint			

FND-022	Sin DOMPurify (preventivo — no hay dangerouslySetInnerHTML)	Bajo	Preventivo
No se encontró ningún uso de <code>dangerouslySetInnerHTML</code> , <code>eval</code> , <code>innerHTML</code> ni <code>Function()</code> en el codebase. React protege contra XSS por construcción. Acción preventiva documentada: instalar DOMPurify antes de introducir rich text editing. CVSS: 0 CWE-79			
Sprint de resolución: —			

FND-023	SECURITY.md con template genérico (email de @tiangolo)	Bajo	Resuelto
SECURITY.md actualizado con el email real del equipo NGcourses para recibir reportes de vulnerabilidades responsables (coordinated disclosure). Se documentó el proceso de 90 días antes de divulgación pública. CVSS: 0–2 N/A			
Sprint de resolución: Anterior			

FND-024	Sin pre-commit hooks (gitleaks / detect-secrets)	Bajo	Resuelto
Se creó <code>.pre-commit-config.yaml</code> con gitleaks v8 para escanear secretos antes de cada commit. CI también ejecuta <code>gitleaks detect --source .</code> como paso de validación en el pipeline de GitHub Actions. CVSS: 0 CWE-540			
Sprint de resolución: Anterior			

FND-025	Sin Sentry en el frontend (errores de browser invisibles)	Bajo	Resuelto
Se instaló <code>@sentry/nextjs</code> . Se crearon <code>sentry.client.config.ts</code> , <code>sentry.server.config.ts</code> y <code>sentry.edge.config.ts</code> . <code>next.config.ts</code> envuelto con <code>withSentryConfig</code> . CSP actualizado con dominios <code>*.sentry.io</code> e <code>*.ingest.sentry.io</code> . Sentry desactivado si <code>NEXT_PUBLIC_SENTRY_DSN</code> no está definido (seguro en HTTP/EC2). CVSS: 3.1 CWE-778			
Sprint de resolución: Este sprint			

FND-026	package-lock.json en .gitignore pero versionado	Bajo	Resuelto
Se eliminó package-lock.json del .gitignore raíz. El archivo permanece versionado (correcto para builds reproducibles). Se eliminó la inconsistencia que confundía a colaboradores y podía provocar omisiones accidentales. CVSS: 0 N/A			
Sprint de resolución: Código			

FND-027	frontend/Dockerfile copia .env* con COPY . .	Bajo	Resuelto
Se creó frontend/.dockerignore con .env*, .env.local, .env*.local, node_modules, .next, .git y .vscode. Builds locales ya no pueden embeber credenciales en la imagen Docker. En CI no había riesgo (runner no tiene .env.local). CVSS: 5.5 local / 0 CI CWE-538			
Sprint de resolución: Código			

4. Controles Efectivos (sin hallazgos)

Los siguientes controles estaban correctamente implementados al momento de la auditoría y deben mantenerse como baseline de seguridad:

Control	Implementacion
SQL Injection	SQLModel/SQLAlchemy parametrizado en todas las queries. Sin uso de text() ni f-strings con SQL.
Deserializacion insegura	Sin pickle, yaml.load(unsafe), eval ni exec en el codebase.
SSRF	Sin URLs controladas por el usuario en llamadas requests/httpx. URLs de Bunny y PayPal hardcodeadas en servicios internos.
Password hashing	bcrypt via passlib con rounds default (>10). Sin MD5/SHA-1 para passwords.
CI/CD credentials	OIDC + AssumeRole en GitHub Actions. Sin credenciales AWS hardcodeadas en el repo.
Webhook validation	Firma HMAC validada en el webhook de Bunny.net cuando BUNNY_WEBHOOK_SECRET esta configurado.
Lockfiles versionados	uv.lock y package-lock.json presentes. Builds reproducibles en CI y local.
Validacion de defaults	_check_default_secret rechaza 'changethis' en staging/produccion. ValidationError si SECRET_KEY no esta definida.

5. Proximos Pasos

1. FND-020 — HTTPS / TLS

Cuando se asigne el subdominio ncchamp: activar Traefik con Let's Encrypt (docker-compose.traefik.yml ya existe), setear `ENABLE_HTTPS=true` en `.env.prod`, verificar cookies Secure y HSTS, remover el `remotePattern` de IP en `next.config.ts`.

2. Sentry frontend — Activacion

Crear proyecto 'ngcourses-frontend' en sentry.io. Agregar `NEXT_PUBLIC_SENTRY_DSN` como GitHub Secret y build-arg en `deploy.yml`. Agregar `SENTRY_AUTH_TOKEN` para upload de source maps. Agregar org y project a `withSentryConfig`.

3. CI — Dependency scanning

Agregar pasos `pip-audit` (backend) y `npm audit --audit-level=high` (frontend) en el pipeline de GitHub Actions como puerta obligatoria de PR.

4. Re-auditoria

Una vez activo HTTPS y Sentry: re-auditoria de los hallazgos cerrados para confirmar la efectividad de los controles en produccion real. Considerar pentest externo o /ultrareview de la rama main.

Fin del reporte — NGcourses © 2026